

YubiKey unter Windows 10 und 11

Installations-, Einrichtungs- und Verwaltungsanleitung
mit Praxisbeispiel **Sophos Central (Enterprise)**

Zielgruppe	Anwender und Administratoren, die einen YubiKey (Serie 5, Security Key, Bio) lokal unter Windows 10/11 einrichten, verwalten und als zweiten Faktor (2FA/MFA) an Konten binden wollen.
Software-Stand	Yubico Authenticator 7.4.2 (09.09.2026) · YubiKey Manager CLI ykman 5.9.2 (30.06.2026) – Downloads am 25.09.2026 geladen, Hashwerte berechnet, GPG- und Authenticode-Signatur geprüft (Kapitel 3).
Grundlage	Offizielle Dokumentation von Yubico (docs.yubico.com , support.yubico.com , developers.yubico.com , Quellcode der Yubico-Tools auf GitHub) und Sophos (docs.sophos.com , community.sophos.com). Alle Quellen im Anhang A.
Aufbau	1 Funktionsweise · 2 Methodenwahl · 3 Downloads & Prüfsummen · 4 Installation · 5 Ersteinrichtung · 6 Standardweg: Key an Konto binden · 7 Mehrere Konten · 8 Beispiel Sophos Central · 9 Verwaltung · 10 Verlust & Reset · 11 Fehlerbehebung · 12 Testprotokoll · Anhänge

Hinweis zu Menübezeichnungen: Windows, Browser, Yubico Authenticator und Sophos Central werden laufend aktualisiert. Die Pfade in dieser Anleitung entsprechen dem Stand September 2026. Weicht eine Beschriftung ab, gilt sinngemäß der gleiche Weg. Deutsche und englische Bezeichnungen sind jeweils angegeben: **Deutsch** / *English*.

Inhaltsverzeichnis

1 Wie ein YubiKey funktioniert	3
1.1 Das Prinzip: Besitz + Wissen	3
1.2 FIDO2/WebAuthn: warum der Key phishing-resistent ist	3
1.3 Die Anwendungen (Applets) auf dem YubiKey	3
1.4 Begriffe: Passkey, Sicherheitsschlüssel, TOTP	4
2 Welche Methode für welches Konto?	4
3 Benötigte Software, offizielle Downloads und Prüfsummen	4
3.1 Geprüfte Downloads (Direktlinks und Hashwerte)	5
3.2 Download unter Windows prüfen (PowerShell)	6
4 Installation unter Windows 10 und 11	6
4.1 Yubico Authenticator installieren	6
4.2 Optional: YubiKey Manager CLI (ykman) installieren	7
4.3 Optionale Komponenten	7
5 Ersteinrichtung des YubiKeys	7
5.1 Key identifizieren und dokumentieren	7
5.2 FIDO2-PIN setzen (Pflicht für Passkeys)	8
5.3 Optional: OATH-Passwort setzen	8
5.4 Optional: Nicht benötigte Schnittstellen abschalten	8
5.5 PIV- und OpenPGP-Standard-PINs ändern (nur bei Nutzung)	9
6 Der Standardweg: YubiKey als 2FA an ein Konto binden	9
6.1 Variante FIDO2 / Sicherheitsschlüssel / Passkey (empfohlen)	9
6.2 Variante TOTP mit dem Yubico Authenticator	9
7 Ein YubiKey für mehrere Konten, mehrere Keys pro Konto	10
8 Praxisbeispiel: YubiKey für ein Sophos-Central-Konto (Enterprise)	10
8.1 Voraussetzungen	11
8.2 Variante A – YubiKey als Passkey registrieren (empfohlen)	11
8.3 Variante B – YubiKey als TOTP-Authenticator (OATH)	11
8.4 MFA eines Administrators zurücksetzen (Key verloren)	12
8.5 Enterprise-Option: Anmeldung über Identity Provider (Entra ID / Okta)	12
8.6 Abgrenzung: Sophos Firewall (Benutzerportal, VPN)	12
9 YubiKey im Alltag verwalten	12
9.1 Yubico Authenticator – Bereiche	12
9.2 Kommandoreferenz ykman 5.9.2	12
9.3 Passkeys prüfen und aufräumen	13
9.4 Empfohlene Betriebsregeln	13
10 Verlust, Defekt und Zurücksetzen	13
10.1 YubiKey verloren oder gestohlen	13
10.2 Anwendungen zurücksetzen	13
11 Fehlerbehebung	14
12 Testprotokoll (Abnahme der Anleitung)	15
Anhang A Quellen (offizielle Dokumentation)	15
Anhang B Glossar	17

1 Wie ein YubiKey funktioniert

Ein YubiKey ist ein kleiner Hardware-Sicherheitsschlüssel mit einem eigenen, manipulationsgeschützten Chip (Secure Element). Er wird per USB-A, USB-C oder Lightning angeschlossen bzw. per NFC an Smartphones gehalten. Er braucht weder Batterie noch Treiber: Windows erkennt ihn als Tastatur (HID), als FIDO-Gerät und als Smartcard-Leser (CCID). Das Entscheidende: **Die geheimen Schlüssel verlassen den YubiKey nie.** Sie können weder ausgelesen noch kopiert werden. Auch die Firmware lässt sich bewusst nicht aktualisieren. Das schützt vor manipulierten Updates, bedeutet aber, dass neue Funktionen nur mit einem neuen Key kommen.

1.1 Das Prinzip: Besitz + Wissen

Ein Konto mit YubiKey ist durch zwei unabhängige Faktoren geschützt: etwas, das Sie **wissen** (Passwort und/oder PIN des Keys), und etwas, das Sie **besitzen** (den physischen YubiKey). Mit dem gestohlenen Passwort allein kommt ein Angreifer nicht weiter. Die Berührung der goldenen Kontaktfläche (*Touch*) bestätigt zusätzlich, dass ein Mensch vor dem Rechner sitzt. Schadsoftware kann den Key deshalb nicht unbemerkt aus der Ferne benutzen.

1.2 FIDO2/WebAuthn: warum der Key phishing-resistent ist

Die modernste und empfohlene Methode ist **FIDO2/WebAuthn** (im Web meist »Sicherheitsschlüssel«, »Security Key« oder »Passkey« genannt). Sie beruht auf Public-Key-Kryptografie:

1. **Registrierung:** Der YubiKey erzeugt für *genau diese* Website (z. B. `central.sophos.com`) ein neues Schlüsselpaar. Der **öffentliche** Schlüssel geht an den Dienst, der **private** bleibt im Key.
2. **Anmeldung:** Der Dienst schickt eine Zufallszahl (Challenge). Der Browser gibt die tatsächlich besuchte Domain mit. Nach PIN-Eingabe und Berührung signiert der Key die Challenge mit dem privaten Schlüssel.
3. **Prüfung:** Der Dienst prüft die Signatur mit dem hinterlegten öffentlichen Schlüssel. Passt sie, ist die Anmeldung erfolgreich.

Weil die Domain in die Signatur eingeht, liefert der Key auf einer gefälschten Seite (z. B. `central-sophos.com`) keine gültige Antwort. Anders als bei Codes zum Abtippen kann der Nutzer den Faktor also gar nicht an Phisher weitergeben. Außerdem wird kein gemeinsames Geheimnis beim Dienst gespeichert: Ein Datenleck beim Anbieter verrät nur öffentliche Schlüssel.

1.3 Die Anwendungen (Applets) auf dem YubiKey

Ein YubiKey 5 enthält mehrere voneinander unabhängige Anwendungen. Jede hat eigene Zugangsdaten und lässt sich einzeln zurücksetzen, ohne die anderen zu berühren.

Anwendung	Wofür	Schutz / Standardwerte	Kapazität
FIDO2 / WebAuthn (Passkeys)	Passwortlose Anmeldung oder 2FA im Browser und in Apps; phishing-resistent	FIDO2-PIN: ab Werk keine , 4–63 Zeichen. Nach 3 Fehlversuchen Key abziehen und neu einstecken; nach 8 Fehlversuchen gesperrt → nur noch Reset (löscht alle Passkeys)	Firmware < 5.7: 25 Passkeys ab 5.7: 100 Passkeys
FIDO U2F	Klassischer »Sicherheitsschlüssel« als 2. Faktor (Vorgänger von FIDO2)	Touch; teilt sich den FIDO-Reset mit FIDO2	unbegrenzt (es wird nichts auf dem Key gespeichert)
OATH (TOTP/HOTP)	6-/8-stellige Einmalcodes wie Google/Microsoft Authenticator; Codes zeigt der Yubico Authenticator an, das Geheimnis liegt im Key	Optionales OATH-Passwort; optional Touch pro Konto	Firmware < 5.7: 32 Konten ab 5.7: 64 Konten
Yubico OTP / Slots	2 programmierbare Slots: Yubico OTP, statisches Passwort, Challenge-Response, HOTP	Kurz berühren (1–2,5 s) = Slot 1, lang (3–5 s) = Slot 2; optional Zugriffscode	2 Slots
PIV (Smartcard)	Zertifikate: Windows-/AD-Smartcard-Anmeldung, S/MIME, Signaturen	PIN 123456 , PUK 12345678 , Management Key 010203040506070801020304050607080102030405060708 (ab Werk; unbedingt ändern), je 3 Versuche	24 Zertifikats-Slots

Anwendung	Wofür	Schutz / Standardwerte	Kapazität
OpenPGP	GPG-Schlüssel für E-Mail-Verschlüsselung, Signaturen, SSH	User-PIN 123456 , Admin-PIN 12345678 (ab Werk; ändern), je 3 Versuche	3 Schlüssel (S/E/A)

Die Anwendungen laufen über drei USB-Schnittstellen: **OTP** (meldet sich als Tastatur), **FIDO** (U2F und FIDO2) und **CCID** (Smartcard: PIV, OATH, OpenPGP). Eine Schnittstelle ist aktiv, solange mindestens eine ihrer Anwendungen aktiviert ist.

1.4 Begriffe: Passkey, Sicherheitsschlüssel, TOTP

Begriff	Bedeutung in dieser Anleitung
Passkey (auffindbare Anmeldeinformation / <i>discoverable credential</i>)	FIDO2-Schlüssel, der auf dem YubiKey <i>gespeichert</i> wird und auch den Benutzernamen kennt. Er belegt einen der 25/100 Plätze und ist mit der FIDO2-PIN geschützt. Anmeldung oft ganz ohne Passwort.
Sicherheitsschlüssel (nicht auffindbar / U2F-artig)	FIDO-Schlüssel, der nicht auf dem Key gespeichert, sondern bei jeder Anmeldung aus einem Geheimnis im Key abgeleitet wird. Belegt keinen Speicherplatz, daher unbegrenzt viele Konten.
TOTP (Time-based One-Time Password)	Sechsstelliger Code, der alle 30 s wechselt. Mit dem YubiKey liegt das Geheimnis im Key statt im Handy. Funktioniert mit jedem Dienst, der eine »Authenticator-App« anbietet, ist aber nicht phishing-resistent.

2 Welche Methode für welches Konto?

Als Faustregel gilt: **so weit oben in dieser Liste wie der Dienst es erlaubt.**

Rang	Methode	Wann nutzen?	Bezeichnung beim Dienst (typisch)
1	FIDO2 Passkey auf dem YubiKey	Dienst bietet »Passkey« an; höchste Sicherheit, phishing-resistent, schnell	Passkey, Sicherheitsschlüssel, Security key, Hardware key, WebAuthn
2	FIDO U2F / nicht auffindbarer Sicherheitsschlüssel	Dienst bietet »Sicherheitsschlüssel« als 2. Faktor; Passkey-Speicher knapp	Security key, U2F, 2-Step Verification > Security key
3	OATH-TOTP im YubiKey (Yubico Authenticator)	Dienst bietet nur eine »Authenticator-App« an (QR-Code + 6-stelliger Code)	Authenticator app, TOTP, Google Authenticator, 2FA-App
4	Yubico OTP / statisch / Challenge-Response	Nur Sonderfälle (ältere Systeme, Passwortmanager wie KeePassXC, lokale Windows-Anmeldung mit Yubico Login)	Yubico OTP, YubiKey (OTP)

Empfehlung

Registrieren Sie bei **jedem** Konto mindestens **zwei** YubiKeys (Haupt- und Ersatzschlüssel) und bewahren Sie die Wiederherstellungscodes des Dienstes offline auf. Yubico empfiehlt ausdrücklich, den Ersatzschlüssel gleich bei der Ersteinrichtung mit zu registrieren. Ein YubiKey lässt sich nicht klonen oder sichern.

3 Benötigte Software, offizielle Downloads und Prüfsummen

Für die Grundfunktion (FIDO2/Passkey im Browser) braucht Windows **keine** Zusatzsoftware: Windows 10 (ab 1903) und Windows 11 bringen die WebAuthn-Schnittstelle mit. Für die **Verwaltung** des Keys (PINs, Passkeys ansehen und löschen, TOTP-Konten, Schnittstellen) stellt Yubico folgende Werkzeuge bereit:

Werkzeug	Zweck	Erforderlich?
Yubico Authenticator (Desktop-App)	Zentrales GUI-Werkzeug: TOTP-Codes, Passkeys, FIDO2-PIN, PIV-Zertifikate, OTP-Slots, Schnittstellen. Ersetzt den YubiKey Manager (GUI) , der am 19.02.2026 End-of-Life erreicht hat.	Ja (empfohlen)
YubiKey Manager CLI (ykman)	Kommandozeile für Skripte, Automatisierung, Diagnose, Reset	Optional (Admins)
YubiKey Smart Card Minidriver	Windows-Smartcard-Integration für PIV (Zertifikatsanmeldung im AD)	Nur für PIV/Smartcard-Logon

Werkzeug	Zweck	Erforderlich?
Yubico Login for Windows	2FA für die <i>lokale</i> Windows-Anmeldung (Challenge-Response; nur lokale Konten, nicht Entra ID, nicht Windows on Arm)	Nur bei Bedarf

3.1 Geprüfte Downloads (Direktlinks und Hashwerte)

Die folgenden zwei Installer wurden am **25.09.2026** von Yubicos offiziellen GitHub-Releases geladen. Ihre Hashwerte wurden berechnet, die OpenPGP-Signatur (.sig) gegen die auf developers.yubico.com > [Software Signing](#) veröffentlichten Yubico-Schlüssel geprüft (»Good signature«), und die Windows-Codesignatur (Authenticode) lautet auf **Yubico AB**.

Yubico Authenticator 7.4.2 (Windows x64)

Datei	yubico-authenticator-7.4.2-win64.msi (61.698.048 Bytes)
Download	https://github.com/Yubico/yubioath-flutter/releases/download/7.4.2/yubico-authenticator-7.4.2-win64.msi
Signatur	https://github.com/Yubico/yubioath-flutter/releases/download/7.4.2/yubico-authenticator-7.4.2-win64.msi.sig
SHA-256	9f252a0f2ef06c11a580bb95952ec4ebdc6f1e4d533341aee920f790f5c327f4
SHA-1	4ce57e015fbef71211d0ba6f95fd97a30800ce4e
MD5	84e14de45a247204b09b7951d826bd01
GPG-Signatur	Good signature – Dennis Fokin <dennis.fokin@yubico.com>, Hauptschlüssel 9E88 5C03 02F9 BB91 6752 9C2D 5CBA 11E6 ADC7 BCD1 (signiert mit Unterschlüssel D691 9FBF 48C4 84F3 CB7B 71CD 870B 8825 6690 D8BC), Signatur vom 09.09.2026
Authenticode	Signiert von Yubico AB (DigiCert Trusted G4 Code Signing CA), Zertifikat gültig bis 26.02.2027, Thumbprint A1614CD84976030D49209B56162D9EFA69B73698

YubiKey Manager CLI (ykman) 5.9.2 (Windows x64)

Datei	yubikey-manager-5.9.2-win64.msi (22.396.928 Bytes)
Download	https://github.com/Yubico/yubikey-manager/releases/download/5.9.2/yubikey-manager-5.9.2-win64.msi
Signatur	https://github.com/Yubico/yubikey-manager/releases/download/5.9.2/yubikey-manager-5.9.2-win64.msi.sig
SHA-256	54e5830c56fafcdde80037de490a88de4fe3afc398fc2ad7ccbffcf6b93be9f
SHA-1	c76669740ce99c1d0d696bc5c15801438919baa3
MD5	9ae39157aed672bad813fde6f963cc02
GPG-Signatur	Good signature – Dain Nilsson <dain@yubico.com>, Schlüssel 20EE 325B 86A8 1BCB D3E5 6798 F043 6709 6FBA 95E8, Signatur vom 30.06.2026
Authenticode	Signiert von Yubico AB (DigiCert Trusted G4 Code Signing CA), Zertifikat gültig bis 26.02.2027, Thumbprint A1614CD84976030D49209B56162D9EFA69B73698

Offizielle Übersichtsseiten (falls neuere Versionen erscheinen): yubico.com > [Yubico Authenticator](#) · developers.yubico.com > [yubioath-flutter](#) > [Releases](#) · developers.yubico.com > [yubikey-manager](#) > [Releases](#) · [Smart Card Minidriver](#) · [Yubico Login for Windows](#).

Zu MD5 und neueren Versionen

MD5 ist wie gewünscht angegeben, gilt aber kryptografisch als gebrochen: Zwei verschiedene Dateien können denselben MD5-Wert haben. Maßgeblich sind daher **SHA-256** und die **Signatur »Yubico AB«**. Stimmen beide, ist die Datei echt.

Erscheint eine neuere Version, gelten die obigen Hashwerte nur für die genannte Version. Dann prüfen Sie die Signatur (Abschnitt 3.2). Yubico selbst veröffentlicht keine Hashlisten, sondern Signaturen.

3.2 Download unter Windows prüfen (PowerShell)

Öffnen Sie PowerShell im Download-Ordner (Explorer > Ordner > Adresszeile »powershell« eingeben) und prüfen Sie Hashwert und Signatur:

```
# Hashwerte berechnen (Ergebnis mit Tabelle 3.1 vergleichen)
Get-FileHash .\yubico-authenticator-7.4.2-win64.msi -Algorithm SHA256
Get-FileHash .\yubico-authenticator-7.4.2-win64.msi -Algorithm MD5

# Automatischer Vergleich (gibt True oder False aus)
(Get-FileHash .\yubico-authenticator-7.4.2-win64.msi -Algorithm SHA256).Hash -eq `
'9F252A0F2EF06C11A580BB95952EC4EBDC6F1E4D533341AEE920F790F5C327F4'

# Windows-Codesignatur prüfen: Status muss "Valid" sein, Signer "CN=Yubico AB, ..."
Get-AuthenticodeSignature .\yubico-authenticator-7.4.2-win64.msi |
Format-List Status,
    @{n='Signer'; e={$_.SignerCertificate.Subject}},
    @{n='Thumbprint'; e={$_.SignerCertificate.Thumbprint}}
```

Erwartete Ausgabe der Signaturprüfung:

```
Status      : Valid
Signer       : CN=Yubico AB, O=Yubico AB, L=STOCKHOLM, S=Stockholms län, C=SE
Thumbprint   : A1614CD84976030D49209B56162D9EFA69B73698
```

Ohne PowerShell: Rechtsklick auf die .msi > **Eigenschaften** > Registerkarte **Digitale Signaturen** > Name des Signaturgebers muss **Yubico AB** lauten > **Details** > »Diese digitale Signatur ist gültig.« Alternativ: certutil -hashfile Datei.msi SHA256 bzw. MD5 in der Eingabeaufforderung.

Optional: GPG-Prüfung (mit Gpg4win installiert):

```
gpg --keyserver hks://keyserver.ubuntu.com --recv-keys 9E885C0302F9BB9167529C2D5CBA11E6ADC7BCD1
gpg --keyserver hks://keyserver.ubuntu.com --recv-keys 20EE325B86A81BCBD3E56798F04367096FBA95E8
gpg --verify yubico-authenticator-7.4.2-win64.msi.sig yubico-authenticator-7.4.2-win64.msi
# -> gpg: Good signature from "Dennis Fokin <dennis.fokin@yubico.com>"
gpg --verify yubikey-manager-5.9.2-win64.msi.sig yubikey-manager-5.9.2-win64.msi
# -> gpg: Good signature from "Dain Nilsson <dain@yubico.com>"
```

Die Warnung »This key is not certified with a trusted signature« ist normal. Entscheidend ist »Good signature« und ein Fingerabdruck, der auf der Yubico-Seite Software Signing gelistet ist.

4 Installation unter Windows 10 und 11

Windows 10 und Windows 11 unterscheiden sich für den YubiKey nur in Details der Oberfläche. Die Schritte sind identisch. Voraussetzung: Windows 10 oder 11, 64-Bit (x64), aktuell gepatcht, Administratorrechte für die Installation.

4.1 Yubico Authenticator installieren

1. Installer laden: [yubico-authenticator-7.4.2-win64.msi](#) und gemäß Kapitel 3.2 prüfen.
2. Doppelklick auf die .msi > Assistent mit **Next** bestätigen > Lizenz akzeptieren > Zielordner übernehmen (C:\Program Files\Yubico\Yubico Authenticator) > **Install** > UAC-Abfrage mit **Ja** bestätigen > **Finish**.
3. Startmenü > **Yubico Authenticator** starten. YubiKey einstecken. Der Key erscheint oben links mit Modell, Seriennummer und Firmware-Version.

Unbeaufsichtigte Installation für Administratoren (Softwareverteilung, Intune, GPO):

```
msiexec /i yubico-authenticator-7.4.2-win64.msi /qn /l*v C:\Temp\yubico-auth-install.log
```

Wichtig: Administratorrechte für FIDO-Funktionen

Seit Änderungen in Windows 10/11 dürfen normale Programme nicht mehr direkt mit FIDO-Geräten sprechen. Nur der Browser tut das über die Windows-WebAuthn-Schnittstelle. Für die Bereiche **Passkeys** und die **FIDO2-PIN** muss der Yubico Authenticator deshalb **als Administrator** laufen. Die App zeigt dafür einen Button zum Anheben der Rechte an, oder Sie wählen Rechtsklick > **Als Administrator ausführen**. TOTP (OATH), PIV, OpenPGP und OTP-Slots funktionieren auch ohne Adminrechte.

Alternative ohne Adminrechte: FIDO2-PIN über die Windows-Einstellungen verwalten (Kapitel 5.2).

Nicht die Microsoft-Store-Version verwenden

Die Store-Version kann ihre Rechte wegen der Sandbox in der Regel nicht anheben. Yubico selbst empfiehlt den offiziellen .msi-Installer.

4.2 Optional: YubiKey Manager CLI (ykman) installieren

1. Installer laden: [yubikey-manager-5.9.2-win64.msi](#) und prüfen (Kapitel 3.2).
2. Installieren wie oben. Ziel: C:\Program Files\Yubico\YubiKey Manager CLI. Das Setup trägt den Ordner in die systemweite PATH-Variable ein.
3. **Neues** Terminal öffnen (für FIDO-Befehle: **Terminal (Administrator)**) und testen:

```
PS C:\> ykman --version
YubiKey Manager (ykman) version: 5.9.2

PS C:\> ykman info
Device type: YubiKey 5C NFC
Serial number: 12345678
Firmware version: 5.7.4
Form factor: Keychain (USB-C)
Enabled USB interfaces: OTP, FIDO, CCID
NFC transport is enabled
...
```

(Beispielausgabe; Modell, Seriennummer und Firmware entsprechen Ihrem Key.) FIDO-Befehle ohne Adminrechte enden mit der Meldung »FIDO access on Windows requires running as Administrator.«

4.3 Optionale Komponenten

- **YubiKey Smart Card Minidriver:** nur nötig, wenn PIV-Zertifikate für die Windows-/Active-Directory-Smartcard-Anmeldung genutzt werden. Download: <https://www.yubico.com/support/download/smart-card-drivers-tools/>. Signatur »Yubico AB« wie in 3.2 prüfen.
- **Yubico Login for Windows:** sichert die Anmeldung an *lokalen* Windows-Konten mit Challenge-Response. **Achtung, Aussperrgefahr:** Vorher lokalen Benutzernamen und Passwort kennen und die Konfigurationsanleitung vollständig lesen: [Yubico Login for Windows Configuration Guide](#).

5 Ersteinrichtung des YubiKeys

Diese Schritte werden einmal pro YubiKey durchgeführt, vor der ersten Registrierung bei einem Dienst. Wiederholen Sie sie für den Ersatzschlüssel.

5.1 Key identifizieren und dokumentieren

1. YubiKey einstecken, Yubico Authenticator öffnen > Bereich **Start / Home**.
2. Modell, **Seriennummer** und **Firmware-Version** notieren. Die Firmware bestimmt die Kapazität: ab 5.7 sind es 100 Passkeys und 64 TOTP-Konten, darunter 25 bzw. 32.
3. Den Key physisch beschriften (z. B. »YK-01 Haupt«, »YK-02 Ersatz«) und in einer Inventarliste führen: Seriennummer, Besitzer, registrierte Konten.

5.2 FIDO2-PIN setzen (Pflicht für Passkeys)

Ab Werk hat der YubiKey **keine** FIDO2-PIN. Viele Dienste, darunter Sophos Central, verlangen für Passkeys eine Benutzerverifizierung. Setzen Sie die PIN deshalb vorab. Wählen Sie mindestens 6 Zeichen, erlaubt sind 4 bis 63, auch alphanumerisch.

Weg A – Windows-Einstellungen (ohne Zusatzsoftware)

1. **Einstellungen** (Win + I) > **Konten / Accounts** > **Anmeldeoptionen / Sign-in options**.
2. **Sicherheitsschlüssel / Security Key** > **Verwalten / Manage**.
3. YubiKey einstecken und berühren, wenn er blinkt.
4. Unter **Sicherheitsschlüssel-PIN** auf **Hinzufügen** klicken (bei vorhandener PIN: **Ändern**), PIN zweimal eingeben > **OK**.

Weg B – Yubico Authenticator (als Administrator)

1. Yubico Authenticator **als Administrator** starten > Bereich **Passkeys**.
2. Menü (drei Punkte bzw. Aktionsleiste) > **PIN setzen / Set PIN** > neue PIN zweimal eingeben > **Speichern**.

Weg C – Kommandozeile (Terminal als Administrator)

```
ykman fido access change-pin      # fragt die neue PIN interaktiv ab
ykman fido info                  # zeigt: PIN is set, with 8 attempt(s) remaining
```

PIN-Fehlversuche

Nach **3** Fehlversuchen in Folge muss der Key abgezogen und neu eingesteckt werden. Nach insgesamt **8** Fehlversuchen ist FIDO2 **gesperrt**. Dann hilft nur ein FIDO-Reset, der **alle** Passkeys und U2F-Registrierungen löscht (Kapitel 10). Die PIN deshalb sicher notieren, etwa im Passwortmanager.

Bekanntes Windows-Problem (beheben)

Das Juli-Update 2025 für Windows 11 24H2 (KB5062553) verhinderte das Setzen, Ändern und Zurücksetzen der PIN über die Einstellungen. Behoben ist das ab Build 26100.6584 (KB5065426). Bei älterem Patchstand Weg B oder C verwenden.

5.3 Optional: OATH-Passwort setzen

Wer TOTP-Codes auf dem Key speichert, kann den Zugriff mit einem Passwort schützen. Ohne Passwort kann jeder, der den Key in den Händen hält, die Codes anzeigen lassen. Yubico Authenticator > **Konten / Accounts** > Menü > **Passwort verwalten / Manage password** > **Passwort setzen**. Die Option »Passwort merken« speichert es auf *diesem* PC. CLI: `ykman oath access change`.

5.4 Optional: Nicht benötigte Schnittstellen abschalten

Ein häufiges Ärgernis: Streift man den Key versehentlich, »tippt« die OTP-Schnittstelle eine lange Zeichenfolge wie `ccccbhkevjk...` in das aktive Fenster. Wer Yubico OTP nicht benötigt, schaltet es ab. Das lässt sich jederzeit rückgängig machen.

- Yubico Authenticator > **Start** > **Anwendungen aktivieren/deaktivieren / Toggle applications** > USB > **OTP deaktivieren** > Speichern. Der Key startet dabei neu.
- CLI: `ykman config usb --disable OTP` (wieder aktivieren: `ykman config usb --enable OTP`)

Nicht deaktivieren: **FIDO2/U2F**, wenn Sie Passkeys nutzen, und **OATH**, wenn Sie TOTP-Codes auf dem Key speichern.

5.5 PIV- und OpenPGP-Standard-PINs ändern (nur bei Nutzung)

Wenn Sie PIV (Smartcard) oder OpenPGP verwenden, ändern Sie **sofort** die öffentlich bekannten Standardwerte:

```
ykman piv access change-pin          # Standard: 123456
ykman piv access change-puk          # Standard: 12345678
ykman piv access change-management-key --generate --protect
ykman openpgp access change-pin      # Standard: 123456
ykman openpgp access change-admin-pin # Standard: 12345678
```

6 Der Standardweg: YubiKey als 2FA an ein Konto binden

Fast alle Dienste (Microsoft, Google, GitHub, AWS, Sophos, Passwortmanager usw.) folgen demselben Muster. Die Bezeichnungen variieren, der Ablauf nicht.

6.1 Variante FIDO2 / Sicherheitsschlüssel / Passkey (empfohlen)

1. Im Browser (Edge, Chrome oder Firefox, aktuell) beim Dienst anmelden.
2. Die Sicherheitseinstellungen öffnen: meist **Profil** > **Sicherheit** > **Zwei-Faktor-Authentifizierung** / **Anmeldemethoden** / **MFA**.
3. **Methode hinzufügen** > **Sicherheitsschlüssel**, **Passkey** oder *Security key* wählen. Oft verlangt der Dienst jetzt noch einmal Passwort oder bisherigen Faktor.
4. Windows öffnet den Dialog **Windows-Sicherheit**. Wenn gefragt wird, wo der Passkey gespeichert werden soll, **Sicherheitsschlüssel** / *Security key* wählen, *nicht* »Dieses Windows-Gerät« (Windows Hello) und nicht »iPhone, iPad oder Android-Gerät«.
5. YubiKey einstecken > **FIDO2-PIN** eingeben > goldene Kontaktfläche **berühren**, wenn der Key blinkt.
6. Beim Dienst einen sprechenden Namen vergeben, z. B. »YK-01 Haupt (SN 12345678)«.
7. **Sofort den Ersatzschlüssel** auf die gleiche Weise als zweite Methode registrieren.
8. Wiederherstellungscodes des Dienstes (falls angeboten) herunterladen und offline verwahren.
9. **Test**: abmelden, neu anmelden und mit dem YubiKey bestätigen. Danach mit dem Ersatzschlüssel testen.

Anmeldung danach

Passwort eingeben (entfällt bei rein passwortlosen Passkeys) > der Browser fordert den Sicherheitsschlüssel an > PIN eingeben > berühren > angemeldet. Auf einer Phishing-Seite passiert nichts, weil der Key dort keinen passenden Schlüssel hat.

6.2 Variante TOTP mit dem Yubico Authenticator

Wenn der Dienst nur eine »Authenticator-App« anbietet, speichern Sie das TOTP-Geheimnis im YubiKey statt auf dem Smartphone. Die Codes erhalten Sie dann an jedem PC mit installiertem Yubico Authenticator oder per NFC in der Yubico-Authenticator-App auf Android/iOS.

1. Beim Dienst: **MFA hinzufügen** > **Authenticator-App**. Ein QR-Code wird angezeigt.
2. Yubico Authenticator öffnen, YubiKey einstecken > **Konten** / *Accounts* > **Konto hinzufügen** / *Add account*.
3. **QR-Code aufnehmen** / *Scan QR code* wählen: Die App liest den QR-Code direkt vom Bildschirm. Alternativ das QR-Bild per Drag & Drop in die App ziehen oder den geheimen Schlüssel (Base32) manuell eingeben.
4. Aussteller und Kontoname prüfen. Empfohlen: **Berührung erforderlich** / *Require touch* aktivieren. Dann wird jeder Code erst nach Berühren des Keys angezeigt > **Speichern**.
5. Den angezeigten 6-stelligen Code beim Dienst eingeben > bestätigen.
6. **Ersatzschlüssel**: Denselben QR-Code *vor dem Schließen* auch mit dem zweiten YubiKey scannen. Später ist der QR-Code in der Regel nicht mehr abrufbar.

Dasselbe per Kommandozeile, wenn der Dienst den geheimen Schlüssel als Text anzeigt:

```
ykman oath accounts add -t -i "Beispieldienst" "max.mustermann@firma.de" JBSWY3DPEHPK3PXP
ykman oath accounts list
ykman oath accounts code "Beispieldienst"      # zeigt den aktuellen Code (bei -t: Key berühren)
```

-t = Berührung erforderlich, -i = Aussteller. Standard ist TOTP, 6 Stellen, SHA1, 30 s. Der Beispiel-Schlüssel ist ein Platzhalter.

7 Ein YubiKey für mehrere Konten, mehrere Keys pro Konto

Ja, ein einzelner YubiKey kann an beliebig viele Konten gebunden werden, auch bei verschiedenen Diensten und mehreren Konten beim selben Dienst. Die Konten sind kryptografisch voneinander getrennt: Kein Dienst erfährt, bei welchen anderen Diensten der Key registriert ist. Grenzen setzt nur der Speicher:

Methode	Wie viele Konten pro YubiKey?	Belegt Speicher?
FIDO U2F / nicht auffindbarer Sicherheitsschlüssel	Unbegrenzt	Nein
FIDO2-Passkey (auffindbar)	25 (Firmware < 5.7) bzw. 100 (ab 5.7)	Ja, je Passkey 1 Platz
OATH-TOTP/HOTP	32 (Firmware < 5.7) bzw. 64 (ab 5.7)	Ja, je Konto 1 Platz
Yubico OTP / Challenge-Response	2 Slots (ein Yubico-OTP-Slot funktioniert bei vielen Diensten)	Ja

Umgekehrt gilt: **Ein Konto kann mehrere YubiKeys haben**. Das ist der Standard für Ausfallsicherheit, etwa Haupt- und Ersatzschlüssel, bei Admin-Konten ggf. ein dritter Key im Tresor. Die meisten Dienste erlauben 5 oder mehr Sicherheitsschlüssel, Sophos Central bis zu 10 Methoden je Typ.

Praxisbeispiel Mehrfachnutzung

Ein YubiKey 5C NFC (Firmware 5.7) eines Administrators trägt z. B.: Passkey für Sophos Central, Passkey für Microsoft 365 (Entra ID), Sicherheitsschlüssel für GitHub, TOTP für das Sophos-Firewall-Benutzerportal und TOTP für einen Webhoster. Das sind 5 Konten auf einem Key. Derselbe Ersatzschlüssel ist bei allen fünf ebenfalls registriert.

8 Praxisbeispiel: YubiKey für ein Sophos-Central-Konto (Enterprise)

Sophos Central (Admin, Enterprise Dashboard und Partner Dashboard) erzwingt MFA für alle Administratoren. Seit **November 2024** werden **Passkeys (FIDO2)** nativ unterstützt. Sophos nennt dabei ausdrücklich YubiKeys als gerätegebundene Authentifikatoren. Außerdem gilt:

- Unterstützte Methoden: **Passkey** (z. B. YubiKey) und **Authenticator-App (TOTP)**, etwa Google/Microsoft Authenticator, der Authenticator in Intercept X for Mobile oder eben der YubiKey mit Yubico Authenticator.
- SMS und E-Mail+PIN sind abgekündigt**. Neue Benutzer können sie nicht mehr wählen, und seit 01.05.2025 müssen bestehende Nutzer beim Anmelden auf Passkey oder App umstellen.
- Es müssen **mindestens zwei MFA-Methoden** registriert werden, maximal 10 je Typ. Sophos empfiehlt einen Passkey plus eine Authenticator-App. Ist ein Passkey vorhanden, fragt Sophos ihn bei der Anmeldung zuerst ab.

Empfohlene Kombination für Sophos Central

Methode 1: Passkey auf YubiKey YK-01 (Haupt) · **Methode 2:** Passkey auf YubiKey YK-02 (Ersatz) · optional **Methode 3:** TOTP (Authenticator-App oder YubiKey-OATH) als Rückfallebene. Zwei Hardware-Passkeys erfüllen die Zwei-Methoden-Pflicht und sind beide phishing-resistent.

8.1 Voraussetzungen

- YubiKey mit FIDO2 (YubiKey 5, Security Key oder Bio), FIDO2-PIN gesetzt (Kapitel 5.2).
- Aktueller Browser (Edge, Chrome oder Firefox) unter Windows 10/11. Der Yubico Authenticator ist für den Passkey-Weg *nicht* nötig, der Browser spricht über Windows direkt mit dem Key.
- Zugang zum Sophos-Central-Konto (Benutzername und Passwort der Sophos ID). Für ein bestehendes Konto: eine bereits funktionierende MFA-Methode, um die Änderung zu bestätigen.

8.2 Variante A – YubiKey als Passkey registrieren (empfohlen)

Bei der Erstanmeldung (neuer Administrator): Sophos Central fordert nach dem Passwort automatisch zur MFA-Einrichtung auf und verlangt zwei Methoden. Wählen Sie dort **Passkey** und fahren Sie ab Schritt 4 fort.

Bei einem bestehenden Konto:

1. Unter <https://central.sophos.com> anmelden (Passwort + bisherige MFA).
2. Oben rechts auf das **Profil-Symbol** > **My info** (Meine Informationen) > **Manage MFA** (MFA verwalten). Alternativ über die Sophos ID: **My Profile** > **Manage MFA**.
3. Auf dem Bildschirm **Multi-Factor Authentication** auf das +-Symbol klicken > unter **Set up MFA method** die Option **Passkey** wählen.
4. Windows öffnet den Dialog **Windows-Sicherheit** > **Sicherheitsschlüssel / Security key** wählen (nicht »Dieses Windows-Gerät«, nicht »iPhone/Android«).
5. YubiKey einstecken > **FIDO2-PIN** eingeben > Key **berühren**.
6. Einen Anzeigenamen vergeben, z. B. **YubiKey YK-01 Haupt** > speichern. Die Methode erscheint in der Liste mit Name und »zuletzt verwendet«.
7. Schritte 3–6 mit dem **Ersatzschlüssel** (YK-02) wiederholen.
8. **Test:** abmelden > anmelden > nach dem Passwort erscheint die Passkey-Abfrage > PIN + Berührung > Dashboard erscheint. Test mit YK-02 wiederholen.

Mehrere Sophos-Konten

Derselbe YubiKey kann Passkeys für mehrere Sophos-Konten tragen, z. B. Kunden-Tenant und Partner-Konto mit unterschiedlicher Sophos ID. Jede Registrierung belegt einen eigenen Passkey-Platz (25 bzw. 100). In der Windows-Abfrage wählen Sie ggf. das passende Konto aus.

8.3 Variante B – YubiKey als TOTP-Authenticator (OATH)

Wenn Passkeys organisatorisch nicht gewünscht sind oder als zusätzliche Rückfallmethode:

1. **Profil** > **My info** > **Manage MFA** > + > **Authentication App** > **Set up now**. Ein QR-Code erscheint.
2. Yubico Authenticator > **Konten** > **Konto hinzufügen** > **QR-Code aufnehmen** > Aussteller »Sophos Central« prüfen > **Berührung erforderlich** aktivieren > **Speichern**.
3. Vor dem Schließen denselben QR-Code auch mit dem Ersatzschlüssel scannen (optional).
4. Den im Yubico Authenticator angezeigten 6-stelligen Code (*security code*) in Sophos Central eingeben > bestätigen.
5. **Anmeldung künftig:** Passwort > »Authenticator-App« > Yubico Authenticator öffnen > Key berühren > Code abtippen.

Hinweis: TOTP ist nicht phishing-resistent. Für Admin-Konten ist Variante A vorzuziehen.

8.4 MFA eines Administrators zurücksetzen (Key verloren)

Umgebung	Weg (laut Sophos-Dokumentation)
Sophos Central Admin	Ein Super Admin : My Environment › Users & Groups › Registerkarte <i>Users</i> › Benutzer anklicken › Reset MFA › Reset . Der Benutzer erhält eine E-Mail mit Sicherheitscode, gibt ihn bei der nächsten Anmeldung ein und richtet MFA neu ein.
Sophos Central Enterprise	Symbol Global Settings › Access Control › Admins and Roles › Administrator wählen › Reset MFA › bestätigen. Die Einrichtung startet bei der nächsten Anmeldung.
Eigenes Konto gesperrt	Den eigenen Super Admin bzw. den Partner-Super-Admin kontaktieren. Deshalb immer einen Ersatzschlüssel registrieren.

Nach dem Reset den verlorenen Key in allen anderen Diensten ebenfalls entfernen (Kapitel 10.1).

8.5 Enterprise-Option: Anmeldung über Identity Provider (Entra ID / Okta)

Sophos Central unterstützt die föderierte Anmeldung über **Microsoft Entra ID**, **OpenID Connect** (z. B. Okta) und **AD FS**. Konfiguration: **Global Settings** › **Access Control** › **Sign-in and Identity** › **Sophos sign-in**. Voraussetzung ist eine verifizierte Domain. Bei der Option **IdP-erzwungene MFA** prüft der Identity Provider den zweiten Faktor. Der YubiKey wird dann dort als FIDO2-Sicherheitsschlüssel registriert (z. B. Entra ID: *Authentifizierungsmethoden* › *FIDO2-Sicherheitsschlüssel / Passkey*) und gilt zentral für Sophos Central *und* alle anderen Entra-Anwendungen.

8.6 Abgrenzung: Sophos Firewall (Benutzerportal, VPN)

Die **Sophos Firewall** (Web-Admin, Benutzerportal, SSL/IPsec-VPN, Sophos Connect) ist ein eigenes System. Sie unterstützt **nur OTP (TOTP)**, kein FIDO2. Mit dem YubiKey funktioniert das über OATH: Im Benutzerportal den OTP-QR-Code mit dem Yubico Authenticator scannen (Kapitel 6.2). Bei **Sophos Connect** wird der Code direkt an das Passwort angehängt (PasswortCODE). Hardware-Token-Geheimnisse unterstützt die Firewall nur mit SHA1.

9 YubiKey im Alltag verwalten

9.1 Yubico Authenticator – Bereiche

Bereich (DE / EN)	Funktionen	Adminrechte?
Start / Home	Modell, Seriennummer, Firmware; Anwendungen aktivieren/deaktivieren ; Werksreset; Diagnose	Nein (FIDO-Reset: ja)
Konten / Accounts	TOTP/HOTP: hinzufügen (QR-Code, manuell), Codes anzeigen und kopieren, umbenennen, löschen, anpinnen; OATH-Passwort	Nein
Passkeys	Gespeicherte Passkeys anzeigen und löschen; FIDO2-PIN setzen/ändern; FIDO-Reset; Fingerabdrücke (Bio)	Ja
Zertifikate / Certificates	PIV: Zertifikate, Schlüssel, PIN/PUK/Management Key	Nein
Slots	OTP-Slot 1/2: Yubico OTP, statisches Passwort, Challenge-Response, HOTP	Nein

9.2 Kommandoreferenz ykman 5.9.2

Aufgabe	Befehl
Angeschlossene Keys auflisten / Details	<code>ykman list · ykman info</code>
Schnittstellen anzeigen / ändern	<code>ykman config usb --list · ykman config usb --disable OTP</code>
FIDO-Status (PIN, Restversuche)*	<code>ykman fido info</code>
FIDO2-PIN ändern*	<code>ykman fido access change-pin</code>
Passkeys auflisten / löschen*	<code>ykman fido credentials list · ykman fido credentials delete <ID></code>
TOTP-Konto hinzufügen	<code>ykman oath accounts add -t -i ISSUER NAME SECRET</code>

Aufgabe	Befehl
TOTP-Konten / Codes anzeigen	ykman oath accounts list · ykman oath accounts code [Suchbegriff]
TOTP-Konto umbenennen / löschen	ykman oath accounts rename · ykman oath accounts delete <Name>
OATH-Passwort setzen	ykman oath access change
OTP-Slots anzeigen	ykman otp info
PIV-/OpenPGP-Status	ykman piv info · ykman openpgp info
Hilfe zu jedem Befehl	ykman <befehl> --help

* Erfordert unter Windows ein Terminal **als Administrator**.

9.3 Passkeys prüfen und aufräumen

Da Passkey-Plätze begrenzt sind, lohnt ein regelmäßiger Blick: Yubico Authenticator (als Administrator) › **Passkeys** › FIDO2-PIN eingeben. Die Liste zeigt Dienst (Relying Party, z. B. sophos.com) und Benutzername. Nicht mehr benötigte Einträge über **Passkey löschen** entfernen. Danach die Methode auch beim Dienst entfernen. Alternativ: **Einstellungen** › **Konten** › **Anmeldeoptionen** › **Sicherheitsschlüssel** › **Verwalten** (je nach Windows-Build mit Passkey-Verwaltung).

9.4 Empfohlene Betriebsregeln

- Pro Person mindestens zwei Keys. Der Ersatzschlüssel liegt an einem anderen Ort (Tresor, zu Hause).
- Inventar führen: Seriennummer ↔ Person ↔ registrierte Konten.
- Neue Konten immer mit **beiden** Keys registrieren. Den Ersatzschlüssel dazu kurz holen oder das Konto vormerken.
- PINs nie auf dem Key notieren. Den Key nicht dauerhaft unbeaufsichtigt im Rechner stecken lassen.
- Vierteljährlich die Anmeldung mit dem Ersatzschlüssel testen.

10 Verlust, Defekt und Zurücksetzen

10.1 YubiKey verloren oder gestohlen

1. Mit dem **Ersatzschlüssel** (oder den Wiederherstellungscodes) bei jedem Dienst anmelden.
2. Den verlorenen Key in den MFA-Einstellungen **jedes** Dienstes entfernen (Inventarliste nutzen). Bei Sophos Central: **My info** › **Manage MFA** › Methode entfernen. Ohne Zugang: Reset durch den Super Admin (8.4).
3. Neuen Key beschaffen, einrichten (Kapitel 5) und überall als neuen Ersatzschlüssel registrieren.

Der Finder kann mit dem Key allein wenig anfangen: Für Passkeys fehlt ihm die PIN, für U2F-Konten das Passwort. Trotzdem den Key zeitnah bei allen Diensten austragen.

10.2 Anwendungen zurücksetzen

Achtung – unwiderruflich

Ein Reset löscht alle Zugangsdaten der jeweiligen Anwendung endgültig. Vorher sicherstellen, dass alle betroffenen Konten anderweitig erreichbar sind (Ersatzschlüssel).

Anwendung	Befehl / Weg	Wirkung
FIDO (FIDO2 + U2F)	ykman fido reset (als Admin) · Yubico Authenticator › Passkeys › Zurücksetzen · Windows: Einstellungen › Konten › Anmeldeoptionen › Sicherheitsschlüssel › Verwalten › Zurücksetzen	Löscht alle Passkeys und U2F-Registrierungen und die PIN. Muss innerhalb von ca. 5 s nach dem Einstecken gestartet und per Berührung bestätigt werden.
OATH	ykman oath reset	Löscht alle TOTP/HOTP-Konten und das OATH-Passwort.

Anwendung	Befehl / Weg	Wirkung
PIV	<code>ykman piv reset</code>	Zertifikate gelöscht; PIN 123456, PUK 12345678, Standard-Management-Key.
OpenPGP	<code>ykman openpgp reset</code>	Schlüssel gelöscht; PINs wieder 123456 / 12345678.
OTP-Slot	<code>ykman otp delete 1</code> bzw. <code>2</code>	Löscht die Slot-Konfiguration.
Alles (nur neuere Keys)	<code>ykman config reset</code>	Kompletter Werksreset, sofern vom Modell unterstützt.

11 Fehlerbehebung

Symptom	Ursache / Lösung
Yubico Authenticator: »Failed connecting to the YubiKey. Make sure the application has the required permissions« im Bereich Passkeys	App ohne Adminrechte gestartet. Button zum Anheben nutzen oder App als Administrator starten. Store-Version gegen die .msi tauschen.
ykman: »FIDO access on Windows requires running as Administrator.«	Terminal als Administrator öffnen.
Key blinkt, Browser reagiert nicht	Goldene Fläche berühren (nicht nur einstecken). Bei Nachfrage im Windows-Dialog »Sicherheitsschlüssel« wählen.
Beim Registrieren wird eine PIN verlangt, obwohl keine gesetzt ist	Normal: Windows fordert zum Anlegen einer FIDO2-PIN auf. Seit den Oktober-Updates für Windows 11 24H2/25H2 (Build 26100/26200.6725) passiert das auch, wenn der Dienst nur »UV preferred« anfordert. PIN setzen (5.2).
PIN kann in den Windows-Einstellungen nicht gesetzt/geändert werden	Windows 11 24H2 mit KB5062553: Update installieren (≥ 26100.6584) oder Yubico Authenticator/ykman nutzen.
»PIN blockiert« / »PIN blocked«	8 Fehlversuche. Nur FIDO-Reset möglich (löscht alle Passkeys). Mit dem Ersatzschlüssel anmelden und den Key nach dem Reset neu registrieren.
Zufällige Zeichenfolge »cccc...« erscheint beim Berühren	OTP-Schnittstelle, Slot 1. Harmlos, aber abschaltbar: <code>ykman config usb --disable OTP</code> .
Konten-Bereich zeigt nichts / CCID-Fehler	Dienst Smartcard (SCardSvr) läuft nicht: <code>services.msc</code> > Smartcard > Starten, Starttyp »Manuell (Trigger)«. Andere Smartcard-Software (z. B. exklusiver Zugriff durch Drittanbieter-Middleware) schließen.
Key wird gar nicht erkannt	Anderen USB-Port bzw. keinen Hub verwenden. Im Geräte-Manager müssen »HID-Tastaturgerät«, »USB-Eingabegerät (FIDO)« und ggf. »Smartcard-Leser« erscheinen. Yubico Authenticator > Hilfe & Info > Diagnose ausführen .
Sophos Central bietet »Passkey« nicht an	Browser aktualisieren. Bei föderierter Anmeldung (IdP) wird MFA ggf. beim IdP geregelt (8.5).

12 Testprotokoll (Abnahme der Anleitung)

Dieses Protokoll dient als Testlauf der Anleitung. Arbeiten Sie es an einem Windows-10- und einem Windows-11-Rechner durch und haken Sie jeden Punkt ab.

#	Prüfschritt	Erwartetes Ergebnis	Win 10	Win 11
1	Downloads laden, SHA-256 und MD5 mit Tabelle 3.1 vergleichen	Werte identisch	☐	☐
2	Get-AuthenticodeSignature auf beide .msi	Status Valid, Signer CN=Yubico AB	☐	☐
3	Yubico Authenticator installieren, Key einstecken	Modell, SN, Firmware angezeigt	☐	☐
4	ykman installieren, ykman info	Geräteinfos erscheinen	☐	☐
5	FIDO2-PIN über Windows-Einstellungen setzen	PIN gesetzt; ykman fido info: 8 Versuche	☐	☐
6	Authenticator als Admin > Passkeys öffnen	PIN-Abfrage, leere Liste	☐	☐
7	Test-Passkey auf webauthn.io registrieren und anmelden	Registrierung + Login erfolgreich, Eintrag in Passkeys-Liste	☐	☐
8	TOTP-Test: Testkonto anlegen per ykman oath accounts add -t Test JBSWY3DPEHPK3XPX	Code erscheint nach Berührung	☐	☐
9	Sophos Central: Passkey YK-01 registrieren (8.2)	Methode in »Manage MFA« gelistet	☐	☐
10	Sophos Central: Passkey YK-02 (Ersatz) registrieren	Zweite Methode gelistet	☐	☐
11	Abmelden, Anmelden mit YK-01, dann mit YK-02	Beide Logins erfolgreich	☐	☐
12	Testeinträge aufräumen (webauthn.io-Passkey, OATH »Test« löschen)	Nur produktive Einträge übrig	☐	☐

Getestet von: _____ Datum: _____ Key-Seriennummern: _____

Anhang A Quellen (offizielle Dokumentation)

Stand der Recherche: 25.09.2026. Primärquellen sind die Dokumentation und die Quelltexte von Yubico und Sophos. Die Menüpfade von Sophos Central wurden aus der Sophos-Dokumentation übernommen. Bitte beim ersten Durchlauf mit der tatsächlichen Oberfläche abgleichen (Testprotokoll Kapitel 12).

Yubico

- Yubico Authenticator – Produktseite
<https://www.yubico.com/products/yubico-authenticator/>
- Yubico Authenticator – Benutzerhandbuch
<https://docs.yubico.com/software/yubikey/tools/authenticator/auth-guide/>
- Yubico Authenticator – Releases
<https://developers.yubico.com/yubioath-flutter/Releases/>
- Yubico Authenticator – GitHub
<https://github.com/Yubico/yubioath-flutter/releases>
- YubiKey Manager CLI – Releases
<https://developers.yubico.com/yubikey-manager/Releases/>
- ykman – Benutzerhandbuch
<https://docs.yubico.com/software/yubikey/tools/ykman/>
- YubiKey Manager GUI – End-of-Life-Hinweis
<https://developers.yubico.com/yubikey-manager-gui/>
- Software Signing (GPG-Schlüssel, Authenticode)
https://developers.yubico.com/Software_Projects/Software_Signing.html
- YubiKey 5 Technical Manual
<https://docs.yubico.com/hardware/yubikey/yk-tech-manual/>

- Firmware 5.7 – Neuerungen und Kapazitäten
<https://docs.yubico.com/hardware/yubikey/yk-tech-manual/yk5-firmware-5.7.html>
- Understanding YubiKey PINs
<https://support.yubico.com/hc/en-us/articles/4402836718866-Understanding-YubiKey-PINs>
- Resetting the FIDO2 application
<https://support.yubico.com/hc/en-us/articles/360016648899-Resetting-the-FIDO2-application-on-the-YubiKey>
- How many accounts can I register my YubiKey with?
<https://support.yubico.com/hc/en-us/articles/360013790319-How-many-accounts-can-I-register-my-YubiKey-with>
- Can I duplicate or back up a YubiKey?
<https://support.yubico.com/hc/en-us/articles/360016614880-Can-I-Duplicate-or-Back-Up-a-YubiKey->
- YubiKey firmware is not upgradable
<https://support.yubico.com/hc/en-us/articles/360013708760-YubiKey-firmware-is-not-upgradable>
- Troubleshooting: required permissions (Windows/FIDO)
<https://support.yubico.com/hc/en-us/articles/360016648939-Troubleshooting-Failed-connecting-to-the-YubiKey-Make-sure-the-application-has-the-required-permissions>
- Windows 11 24H2: FIDO-Verwaltung (beheben)
<https://support.yubico.com/hc/en-us/articles/21190316012444--resolved-Windows-Account-Management-in-Windows-11-24H2-Unable-to-manage-FIDO-a-application-on-Security-Key-YubiKey-or-YubiKey-Bio>
- Smart Card Minidriver
<https://www.yubico.com/support/download/smart-card-drivers-tools/>
- Yubico Login for Windows – Configuration Guide
<https://support.yubico.com/hc/en-us/articles/360013708460-Yubico-Login-for-Windows-Configuration-Guide>

Sophos

- Sophos Central – Modern Authentication (Übersicht)
<https://docs.sophos.com/central/customer/help/en-us/ManageYourAccount/ModernAuthentication/ModernAuthAbout/index.html>
- Sophos Central – Passkeys
<https://docs.sophos.com/central/customer/help/en-us/ManageYourAccount/ModernAuthentication/ModernAuthPasskeys/index.html>
- Sophos Central – Passkey einrichten
<https://docs.sophos.com/central/customer/help/en-us/ManageYourAccount/ModernAuthentication/ModernAuthSetUpPasskey/index.html>
- Sophos Central – Zwei Methoden registrieren
<https://docs.sophos.com/central/customer/help/en-us/ManageYourAccount/ModernAuthentication/ModernAuthRegisterTwoMethods/index.html>
- Sophos Central – Authenticator-App einrichten
<https://docs.sophos.com/central/customer/help/en-us/ManageYourAccount/ModernAuthentication/ModernAuthSetUpApp/index.html>
- Sophos Central – MFA verwalten
<https://docs.sophos.com/central/customer/help/en-us/ManageYourAccount/ModernAuthentication/ModernAuthManage/index.html>
- Sophos Central – MFA zurücksetzen
<https://docs.sophos.com/central/customer/help/en-us/ManageYourAccount/ModernAuthentication/ModernAuthReset/index.html>
- Sophos Central Enterprise – MFA einrichten
<https://docs.sophos.com/central/enterprise/help/en-us/ManageYourAccount/MFA/SetupMFA/index.html>
- Sophos Central Enterprise – Reset MFA
<https://docs.sophos.com/central/enterprise/help/en-us/GlobalSettings/AccessControl/AdminsandRoles/ResetMFA/index.html>
- Sophos Central – Federated sign-in (IdP)
<https://docs.sophos.com/central/customer/help/en-us/ManageYourProducts/GlobalSettings/AccessControl/SignIn/FederatedIDP/index.html>
- Sophos Community – Passkeys für Sophos Central
<https://community.sophos.com/sophos-central/b/blog/posts/coming-soon-passkey-authentication-for-sophos-central>
- Sophos Community – Abkündigung SMS und E-Mail-PIN
<https://community.sophos.com/sophos-fusion/b/blog/posts/retiring-sms-and-email-pin-for-sophos-central-sign-ins>
- Sophos Firewall – One-time password
<https://docs.sophos.com/nsg/sophos-firewall/21.5/Help/en-us/webhelp/onlinehelp/AdministratorHelp/Authentication/OneTimePassword/index.html>

Anhang B Glossar

Begriff	Erklärung
2FA / MFA	Zwei-/Mehr-Faktor-Authentifizierung: Anmeldung mit mindestens zwei unabhängigen Faktoren.
AAGUID	Kennung des Authenticator-Modells, die ein Dienst bei FIDO2 sehen kann (z. B. »YubiKey 5 NFC«).
CCID	USB-Klasse für Smartcard-Leser; Transport für PIV, OATH, OpenPGP.
FIDO2 / WebAuthn / CTAP2	Standards der FIDO Alliance und des W3C für phishing-resistente Anmeldung mit Public-Key-Kryptografie.
HID	Human Interface Device, z. B. Tastatur. Über HID laufen OTP und FIDO.
OATH, TOTP, HOTP	Offene Standards für Einmalpasswörter (zeitbasiert bzw. zählerbasiert).
Passkey	Auf einem Authenticator gespeicherte (auffindbare) FIDO2-Anmeldeinformation.
PIV	Personal Identity Verification: Smartcard-Standard (NIST SP 800-73) für Zertifikate.
Relying Party (RP)	Der Dienst, bei dem man sich anmeldet (z. B. sophos.com).
Touch / User Presence	Berührung der Kontaktfläche als Nachweis, dass ein Mensch anwesend ist.
User Verification (UV)	Nachweis, <i>wer</i> den Key benutzt: FIDO2-PIN oder Fingerabdruck (Bio).